

Runbook — enabling the dormant security scaffolds (retired)

SECTION 06-operations-it

TYPE runbook

STATUS

draft

OWNER Founder

UPDATED 2026-08-19

[!WARNING] Retired 2026-08-19 — all three flags this runbook rolled out (`ADEL_APPCHECK_MODE` , `ADEL_RC_REQUIRE_BINDING` , `ADEL_PROTECTED_CONTENT`) belonged to the Firebase Cloud Functions backend, which no longer exists. There is no App Check, no `functions/.env` , no RevenueCat webhook, no `firestore.rules` and no `rcBindings` collection. The procedure cannot be run and must not be adapted.

Go to instead: `../hosting-facts.md` for what the stack actually is, and `docs/RUNBOOK-deploy.md` + `SECURITY.md` in `ay2m/FlyGACA` for how the current service is configured and where to report a security concern.

What replaced each of the three

Retired flag	The concern it addressed	How it is handled now
<code>ADEL_APPCHECK_MODE</code> (App Check on <code>/api/chat</code>)	An unauthenticated LLM endpoint anyone could script	The chat gateway enforces a per-account daily quota (5 questions/day on the free tier) plus per-uid and per-IP burst limiters in front of it. Anonymous callers get the IP tier; the paid surface is the API-key-authenticated <code>/v1/ask</code> , metered per key.
<code>ADEL_RC_REQUIRE_BINDING</code> (RevenueCat identity binding)	A buyer attaching a subscription to an arbitrary account	There is no RevenueCat and no Stripe. Payments are Moyasar , and fulfilment re-derives the purchase from the server's own <code>checkout_intents</code> row rather than from anything the client sends.
<code>ADEL_PROTECTED_CONTENT</code> (server-side paywall)	Paid payloads shipping as public static files	Entitlement is server-owned. The <code>entitlements</code> table is written only by the billing and grants routes; there is simply no route that lets a client write its own plan, credits or pack ownership. The app reads the entitlement to gate UI, never to grant.

The wider point the 2026-05 red-team was making still stands and is now structural rather than flag-gated: policy lives in pure, unit-tested `*-core.ts` modules on the server, the client mirrors are test-enforced against them, and enforcement never depends on the browser behaving.

[!NOTE] [../03-finance/monetization.md](#) still cites this runbook for "set the pack bands" in its launch-gating sequence. The pack bands themselves are current (SAR 249 / 399 / 499); the mechanism is `packEntitlements` in the product repo, not a function env flag. That document has not been reworked and describes the retired client-side launch-mode switches — treat its steps as stale.

DRAFT